Adversary Village at DEF CON 33

LETTHEMIN

Facilitating High-Value Purple Teams Using an Assumed Compromise Approach

Sarah Hume

Adversary Village at DEF CON 33

#WHOAMI

- Sarah Hume
- Purple Team Service Lead @ Security Risk Advisors
- Certifications: CISSP, CRTO, AWS CCP, Google CDL
- Philadelphia, PA (go birds)
- Dog mom

Adversary Village at DEF CON 33

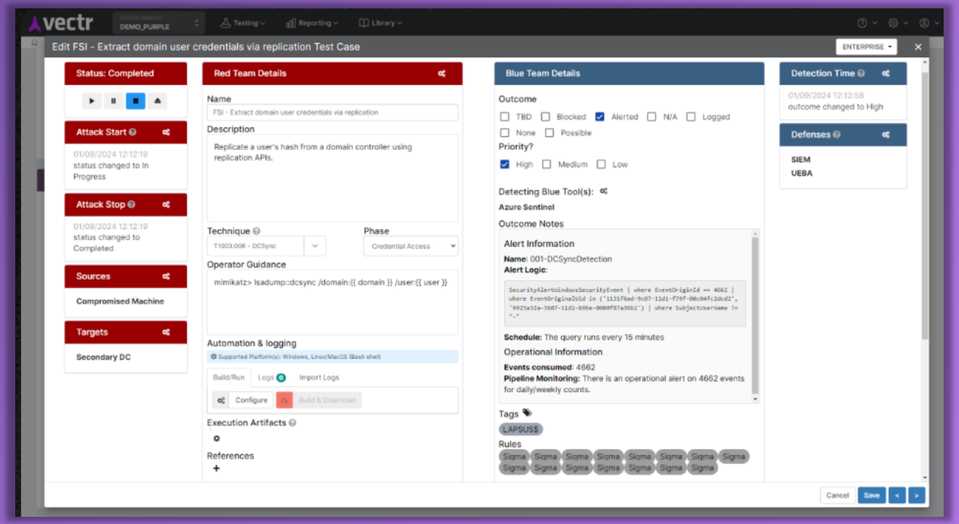
AGENDA

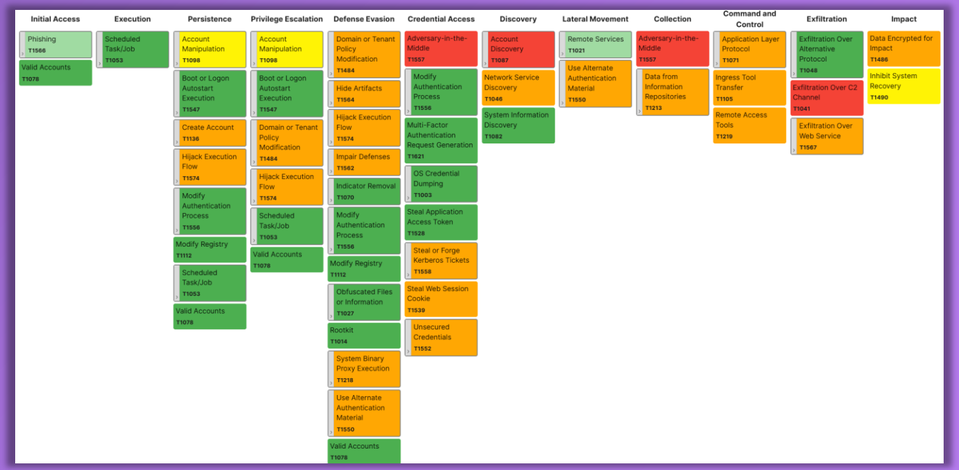
1. Introduction
2. Defining Purple Team Terminology
3. Applying the Assumed Compromise Approach
4. Collecting and Analyzing Results
5. Conclusion

Adversary Village at DEF CON 33

PURPLE TEAM TERMINOLOGY

- Threat Intelligence
- MITRE ATT&CK Framework
  - Tactics, Techniques, and Procedures (TTPs)
  - Adversary PEMDAS
- Red Team
  - Red team engagement vs pen test
- Blue Team
- Red + Blue = Purple Team
- Purple Team Engagement = Collaborative Workshop
- Assumed Compromise Approach





Adversary Village at DEF CON 33

PURPLE TEAM IS

- Bring red and blue teams together
- Test side-by-side in an open book exam format
- Facilitate knowledge transfer between teams
- Execute a threat-driven test plan
- Evaluate security tool effectiveness

PURPLE TEAM IS NOT

BAS

Adversaries cannot fully automate their operations, and neither should your approach to realistic simulations.

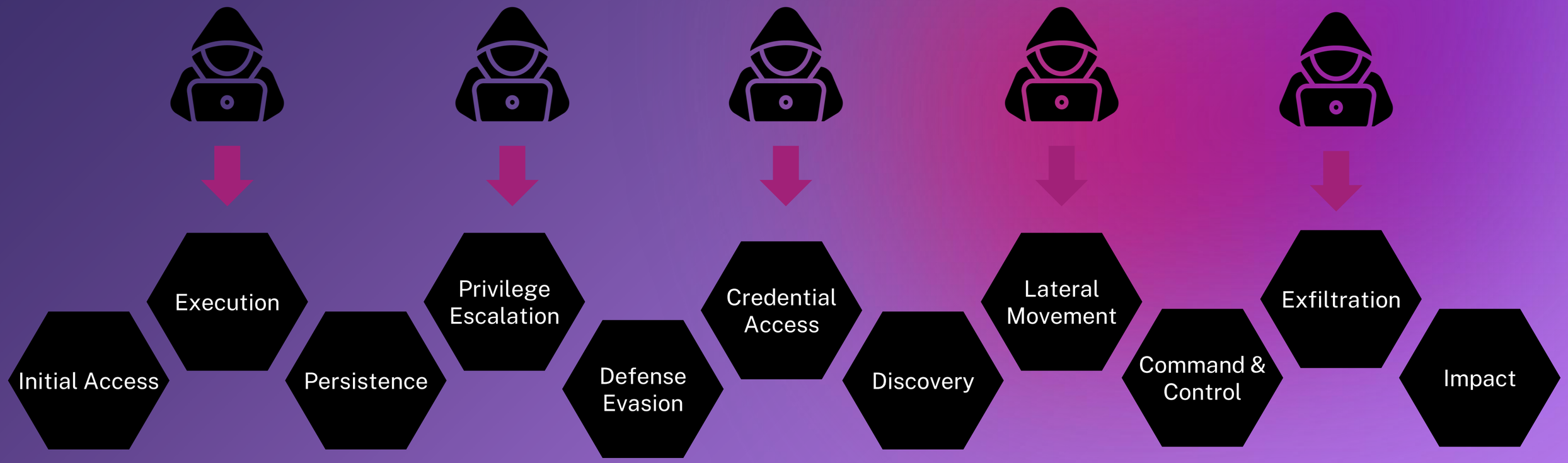
RED

Tests your incident response processes by demonstrating realistic paths to compromise of pre-set flags.

PENTEST

Identifies vulnerabilities and risky configurations that could allow access to sensitive data or cause business impact.

Adversary Village at DEF CON 33



ASSUMED COMPROMISE APPROACH

Adversary Village at DEF CON 33

EXAMPLE SCENARIO:

vectr | ENVIRONMENT Training | Testing | Reporting | Library | Help | Admin | User

Edit Extract domain user credentials via replication Test Case | ENTERPRISE

STATUS: NotPerformed

ATTACK TIMELINE

Attack Start

Attack Stop

ASSETS

Sources
(no Attack Sources specified)

Targets
(no Attack Targets specified)

RED TEAM

Name
Extract domain user credentials via replication

Description
Replicate a user's hash from a domain controller using replication APIs (DCSync).

Observe areas under test:
- DirectoryService Object Access (GetNCChanges for directory user)

Technique: T1003.006 - DCSync

Phase: Credential Access

Operator Guidance
mimikatz> lsadump::dcsync /domain:DEFCON.local /user:sarah

Automation
Supported Platform(s): Windows, Linux/MacOS (Bash shell)

Build/Run | Logs 0 | Import Logs

Configure | Build & Download

Execution Artifacts

BLUE TEAM

Detection Time

Test Case Outcome
Defense Success: N/A
Test Case Outcome
TBD

Defense Activity

Defense Layer	Tool	Defense Outcome
SIEM	Sentinel (Sentinel)	No Outcome Selected
ITDR 2 more...	Defender for Identity (Defender for Identity)	No Outcome Selected

+ Tools

Outcome Notes
Outcome Notes

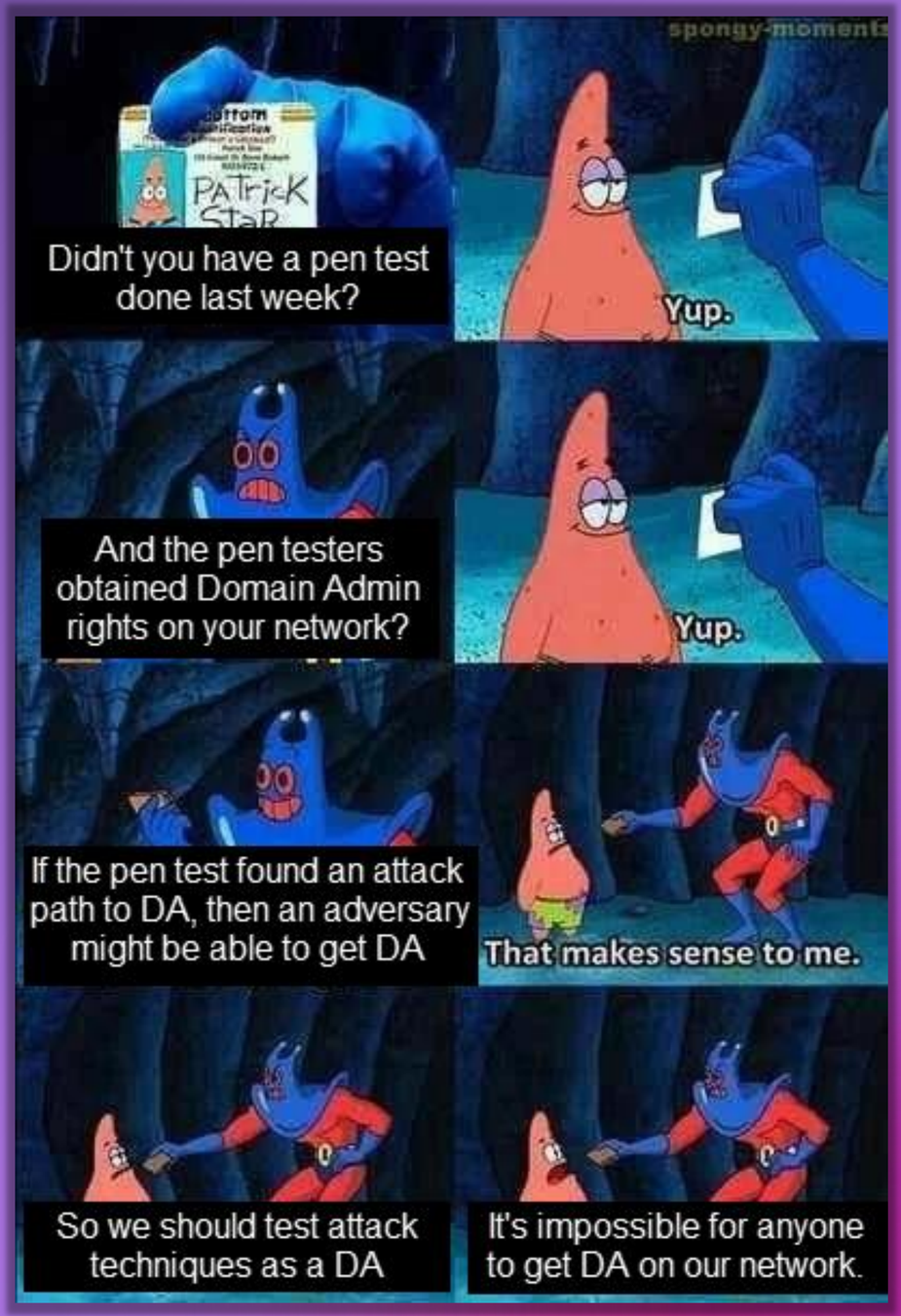
Tags
(no Tags specified)

Cancel | Save | < | >

Adversary Village at DEF CON 33

VISIBILITY, NOT VULNERABILITY

- Assume the stage is set for the attack to run
- We know any organization can be vulnerable at a point in time
- Focus on attacker visibility following their entry into a network
- If the worst happens, what can we detect? What can we prevent? (Do our security tools really do what we think they do / what we paid for them to do?)
- Lower likelihood (often) = higher impact
- Full supervision = low risk

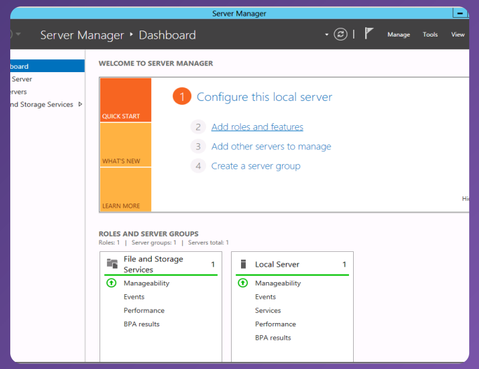


Adversary Village at DEF CON 33

RUNNING DCSYNC

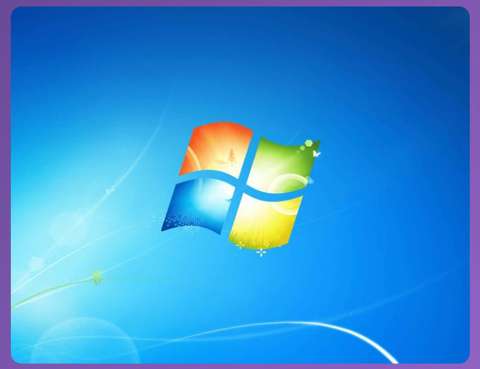
We've granted our red operators DA rights. Now they are running DCSync...

DOMAIN CONTROLLER



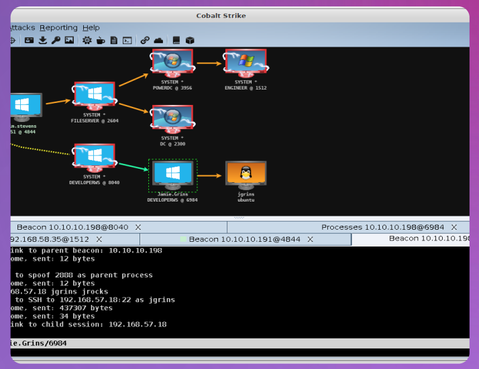
Blocked by Privileged Access Management solution

USER WORKSTATION



Blocked by Endpoint Detection & Response

COBALT STRIKE C2



Blocked by Next Generation Firewall

BUT WHAT IF THE ADVERSARY...?

Adds a rogue workstation to the domain

Breaks into your office building and plugs into your network

Is an insider threat

Makes direct RPC calls from a SOCKS proxy or C2 with unsignatured traffic patterns

Runs from a Linux server with lackluster endpoint protection

Uses a payload unrecognized by AV static signatures (WHAT?!?!?!?)

```
PS C:\Windows\system32>  Get-MpPreference | Select-Object -ExpandProperty ExclusionPath
```

Adversary Village at DEF CON 33

Select Command Prompt

```
Microsoft Windows [Version 10.0.19044.4170]
(c) Microsoft Corporation. All rights reserved.

U:\>net localgroup administrators
Alias name     administrators
Comment        Administrators have complete and unrestricted access to the computer/domain

Members

-------------------------------------------------------------------------------
   \CLT
   \Dom
   \IT
   \prd
   \prd
   \prd
   \prd
   \prd
   \prd
   \VDIUsers

The command completed successfully.
```

```
PS C:\WINDOWS\system32> Get-MpPreference | Select-Object -ExpandProperty ExclusionPath
%Appdata%
%AppData%
%LocalApp
%LocalApp
%LocalApp
%LocalApp
%LocalApp
%PROGRAMF
%SystemRo
%SystemRo
%SystemRo
%USERPROF
%USERPROF
%WinDir%\
%windir%\
%windir%\
%windir%\
%windir%\
%windir%\
%windir%\
%windir%\
%windir%\
%windir%\
%windir%\
%windir%\
\\
\\
C:\Docume
C:\Docume
C:\inetpu
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Progra
C:\Users\
C:\Users\
C:\Users\
C:\Users\
C:\vetspa
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\Window
C:\window
D:\LREHos
D:\LREHos
D:\LREHos
D:\LREHos
D:\Progra
D:\Progra
D:\WebSyn
E: \Progr
E:\MOVEit
E:\Progra
E:\Progra
F:\Progra
F:\Progra
L:\Progra
S:\MSSQL\
T:\Progra
U:\SAS_Wo
X:\McAfee
PS C:\WIN
```

IT MAY NOT BE AS CHALLENGING AS YOU THINK...

Adversary Village at DEF CON 33

PLS HELP WHAT DO

No matter how the attacker tweaks their approach...

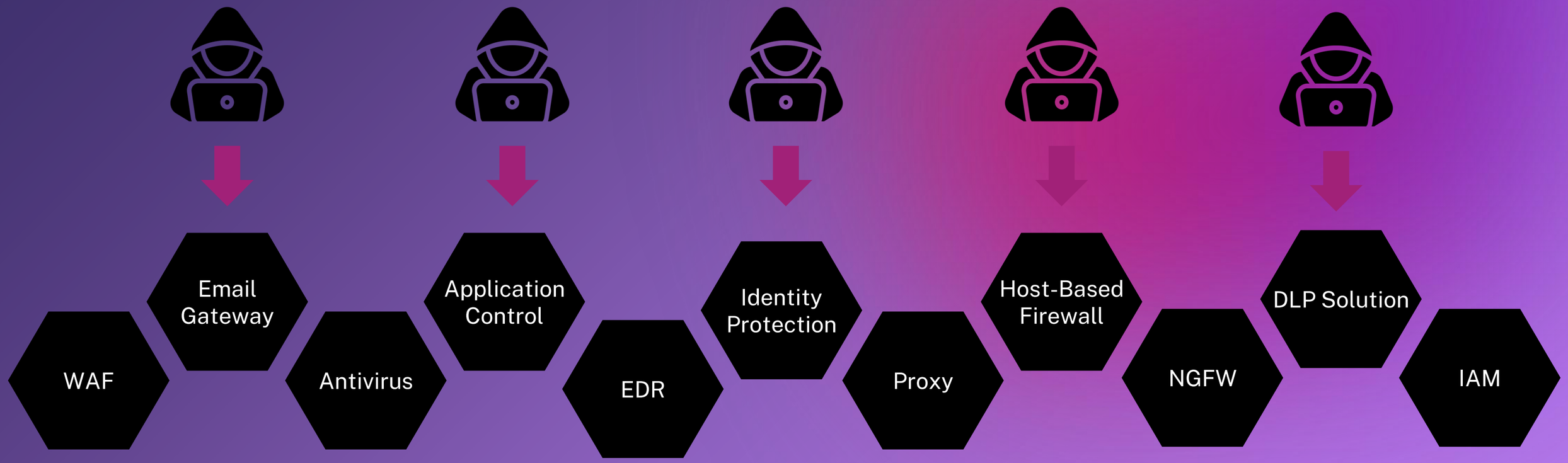
Mimikatz
Secretsdump
PowerShell script
Fancy custom-built tool
On a DC
On a workstation
Remote from a C2
Workstation added to the domain
Rogue device on the network
..and more variations..

The underlying activity is the same...

<u>Directory Service Object Log</u>
Windows Security Event ID 4662
AccessMask 0x100
GUID
1131f6ad-9c07-11d1-f79f-00c04fc2dcd2 1131f6aa-9c07-11d1-f79f-00c04fc2dcd2
9923a32a-3607-11d2-b9be-0000f87a36b2
89e95b76-444d-4c62-991a-0facbeda640c

<u>RPC Call</u>
Interface: DRSUAPI RPC interface
Function: IDL_DRSGetNCChanges

Adversary Village at DEF CON 33



ASSUMED COMPROMISE APPROACH

Doesn't stop at just the user/system access level

Adversary Village at DEF CON 33

EXAMPLE SCENARIO:

vectr | ENVIRONMENT Training | Testing | Reporting | Library | Help | Admin | User

Edit Extract domain user credentials via replication Test Case | ENTERPRISE

STATUS: Completed

ATTACK TIMELINE

Attack Start
07/16/2025 11:15:28
status changed to In Progress

Attack Stop
07/16/2025 11:15:30
status changed to Completed

ASSETS

Sources
- Workstation1.defcon.loca
- DEFCON\sarah

Targets
- DC1.defcon.local

RED TEAM

Name
Extract domain user credentials via replication

Description
Replicate a user's hash from a domain controller using replication APIs (DCSync).

Observe areas under test:
- DirectoryService Object Access (GetNCChanges for directory user)

Technique: T1003.006 - DCSync

Phase: Credential Access

Operator Guidance
mimikatz> lsadump::dcsync /domain:DEFCON.local /user:sarah
Run via a Mythic C2 beacon running on the test workstation.
Beacon running in process test.exe.

Automation
Supported Platform(s): Windows, Linux/MacOS (Bash shell)

Build/Run | Logs 0 | Import Logs

Configure | Build & Download

Execution Artifacts

BLUE TEAM

Detection Time
07/16/2025 11:17:59
outcome changed to High

Test Case Outcome
Defense Success: **Success**
Test Case Outcome
Alerted - High

Defense Activity

Defense Layer	Tool	Defense Outcome
SIEM	Sentinel (Sentinel)	Alerted - High
ITDR 2 more...	Defender for Identity (Defender for Identity)	Alerted - High

+ Tools

Outcome Notes
* Testing required an antivirus exclusion to execute the beacon process without being blocked.
* Domain Administrators are blocked from connecting to the Internet, which is a good secure configuration. We were unable to spawn the beacon process as a DA.
* AD Auditing tool alerted on the creation of a new Domain Admin used for testing
* UEBA tool alerted on a DA account authenticating to a workstation for the first time
* Defender for Identity triggered a high alert for DCSync. These alerts are forwarded to the Sentinel SIEM where they are ticketed and actioned by the team.

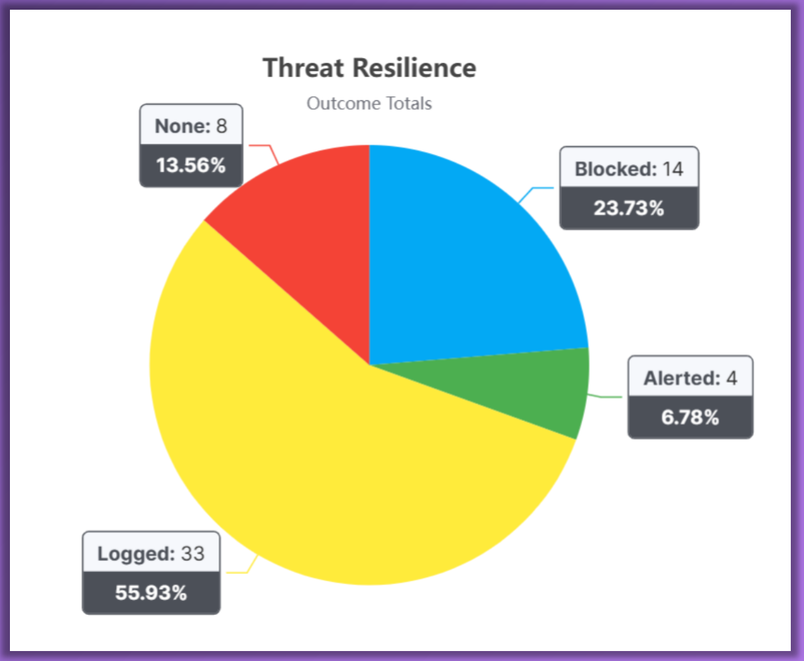
Tags
(no Tags specified)

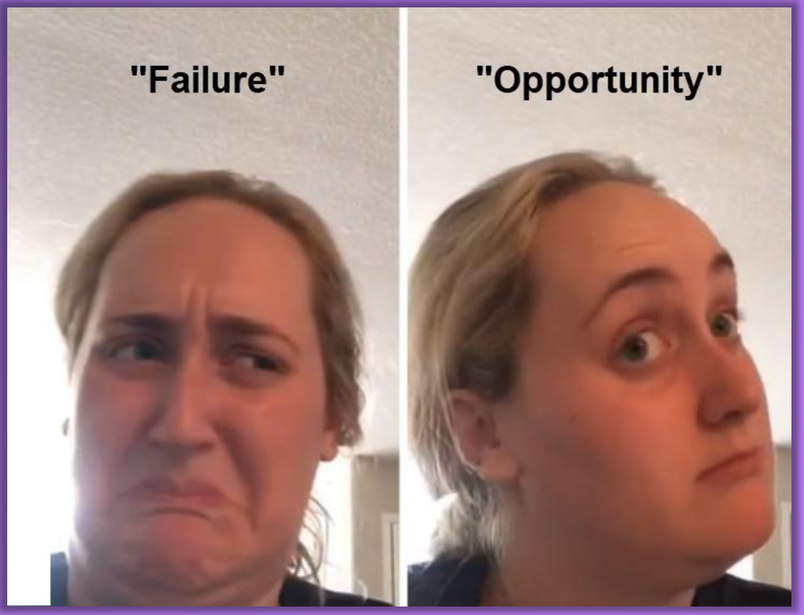
Cancel | Save | < | >

Adversary Village at DEF CON 33

SCORING YOUR PURPLE TEAM

1. Choose a threat intelligence-driven, high priority test plan
2. Use the assumed compromise approach to isolate the security area under test
3. Identify the security tool outcome for each test case
4. Successful (blocked/alerted) outcomes count toward the score, unsuccessful outcomes (logged/none) do NOT count against the score
5. The successful outcomes / total test cases = SCORE





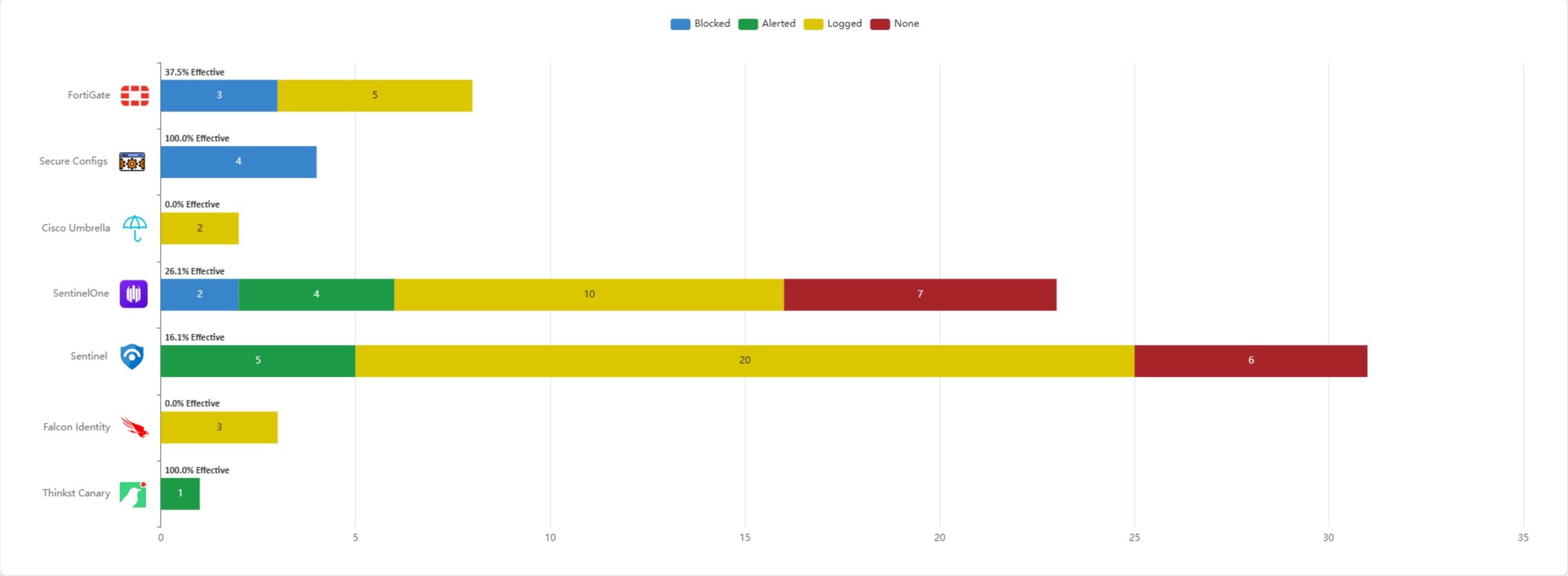
Adversary Village at DEF CON 33

PRIORITIZE REMEDIATION EFFORTS

Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
Phishing T1566	Scheduled Task/Job T1053	Account Manipulation T1098	Account Manipulation T1098	Domain or Tenant Policy Modification T1484	Adversary-in-the-Middle T1557	Account Discovery T1087	Remote Services T1021	Adversary-in-the-Middle T1557	Application Layer Protocol T1071	Exfiltration Over Alternative Protocol T1048	Data Encrypted for Impact T1486
Valid Accounts T1078		Boot or Logon Autostart Execution T1547	Boot or Logon Autostart Execution T1547	Hide Artifacts T1564	Modify Authentication Process T1556	Network Service Discovery T1046	Use Alternate Authentication Material T1550	Data from Information Repositories T1213	Ingress Tool Transfer T1105	Exfiltration Over C2 Channel T1041	Inhibit System Recovery T1490
		Create Account T1136	Domain or Tenant Policy Modification T1484	Hijack Execution Flow T1574	Multi-Factor Authentication Request Generation T1621	System Information Discovery T1082			Remote Access Tools T1219	Exfiltration Over Web Service T1567	
		Hijack Execution Flow T1574	Hijack Execution Flow T1574	Impair Defenses T1562	OS Credential Dumping T1003						
		Modify Authentication Process T1556	Scheduled Task/Job T1053	Indicator Removal T1070	Steal Application Access Token T1528						
		Modify Registry T1112	Valid Accounts T1078	Modify Authentication Process T1556	Steal or Forge Kerberos Tickets T1558						
		Scheduled Task/Job T1053		Modify Registry T1112	Steal Web Session Cookie T1539						
		Valid Accounts T1078		Obfuscated Files or Information T1027	Unsecured Credentials T1552						
				Rootkit T1014							
				System Binary Proxy Execution T1218							

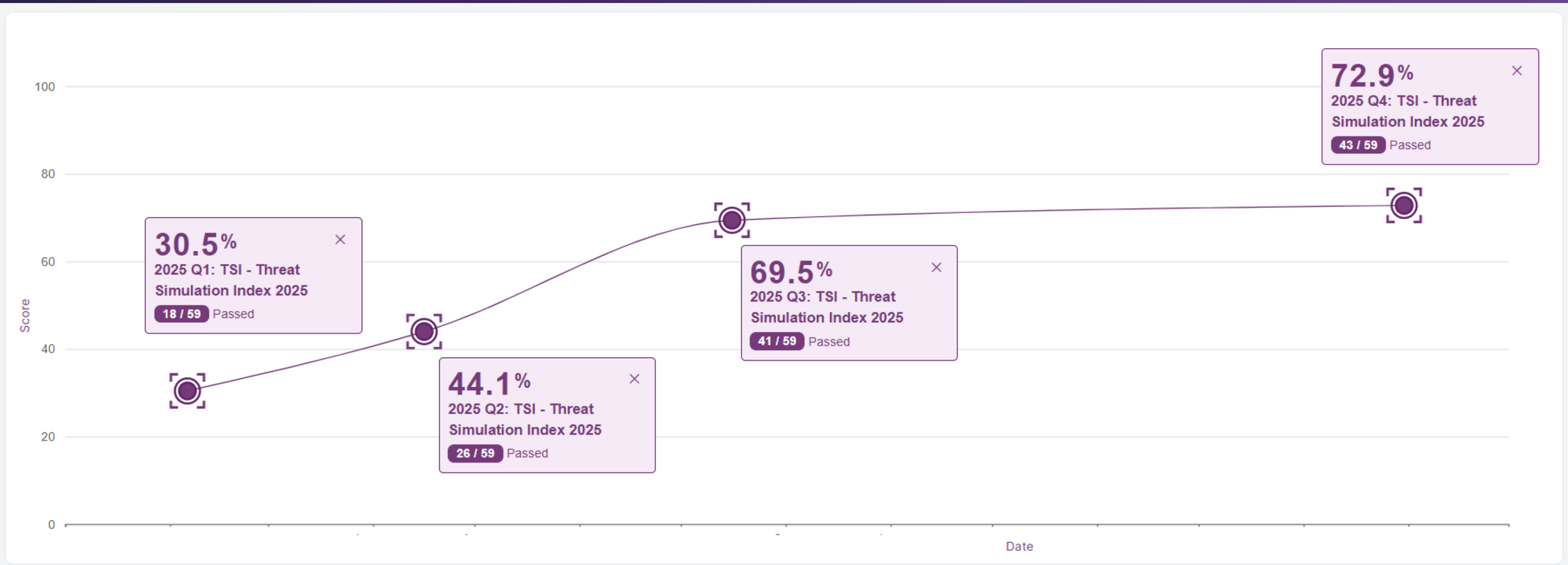
Adversary Village at DEF CON 33

IDENTIFY THEMES



Adversary Village at DEF CON 33

TRACK SUCCESS OVER TIME

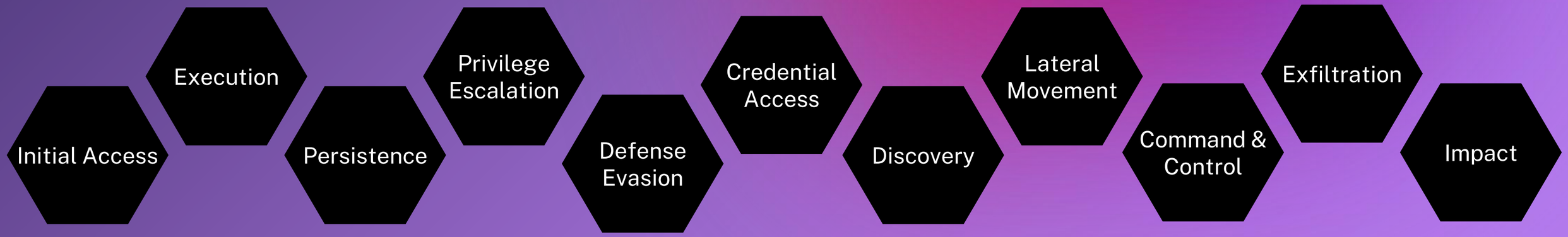


Adversary Village at DEF CON 33

CLOSING THOUGHTS

Maintain focus on the purpose

- Improve your resilience against adversaries
- Protect your organization against current & future threats
- Break the chain
- Flip the burden of perfection



Adversary Village at DEF CON 33

THANK YOU

Let’s connect!

https://www.linkedin.com/in/sarah-hume-353898126/

@sarah__hume

https://github.com/SecurityRiskAdvisors/VECTR